

Left: input becomes part of the command. Right: input is bound as data.

ATTACK

input: ' OR 1=1 --

SELECT * FROM users
WHERE name=' OR 1=1 --'

returns EVERY row (breach)

DEFENSE: parameterized

input: ' OR 1=1 --

SELECT * FROM users
WHERE name = ? (input is data)

no match (safe)